Model-Based Rapid Prototyping of Tiered MFA for Cyber-Physical Systems in Contested Environments

CDT Noah Stephenson and LTC Matthew Wolfe

Department of Systems Engineering, United States Military Academy, West Point, NY

Workshop 3: Security, Resilient, and Robustness of Systems and Software
12 October 2026

The views expressed are those of the authors and do not reflect the official policy or position of the United States Military Academy, the Department of the Army, or the Department of Defense.

Motivation

- Tactical CPS lose connectivity: denied, degraded, intermittent, and limited (DDIL) conditions are the norm
- Degradation is often adversary-induced, through jamming, EW denial, or loss of connectivity
- Tiered MFA defines weaker operating modes the system can fall back to
- Tiers are usually specified by their factor set

Tier	Required factors
Tier 1	RFID + fingerprint
Tier 2	RFID + PIN
Tier 3	RFID + PIN

By factors alone, Tier 2 and Tier 3 are the same tier.

Research questions

1. When two operating tiers share authentication factors, what actually separates them?
2. What security properties hold, and fail to hold, when the operating tier is asserted by the requester rather than derived by the capability?
3. Which defects did the governing model surface that the implementation and its own test suite did not?

Threat model

- Adversary holds a cloned RFID badge and a known PIN, with no enrolled fingerprint
- Adversary can induce a degraded condition, and the requester asserts which tier applies

Approach

MBSE-guided rapid prototyping

1. Govern the model

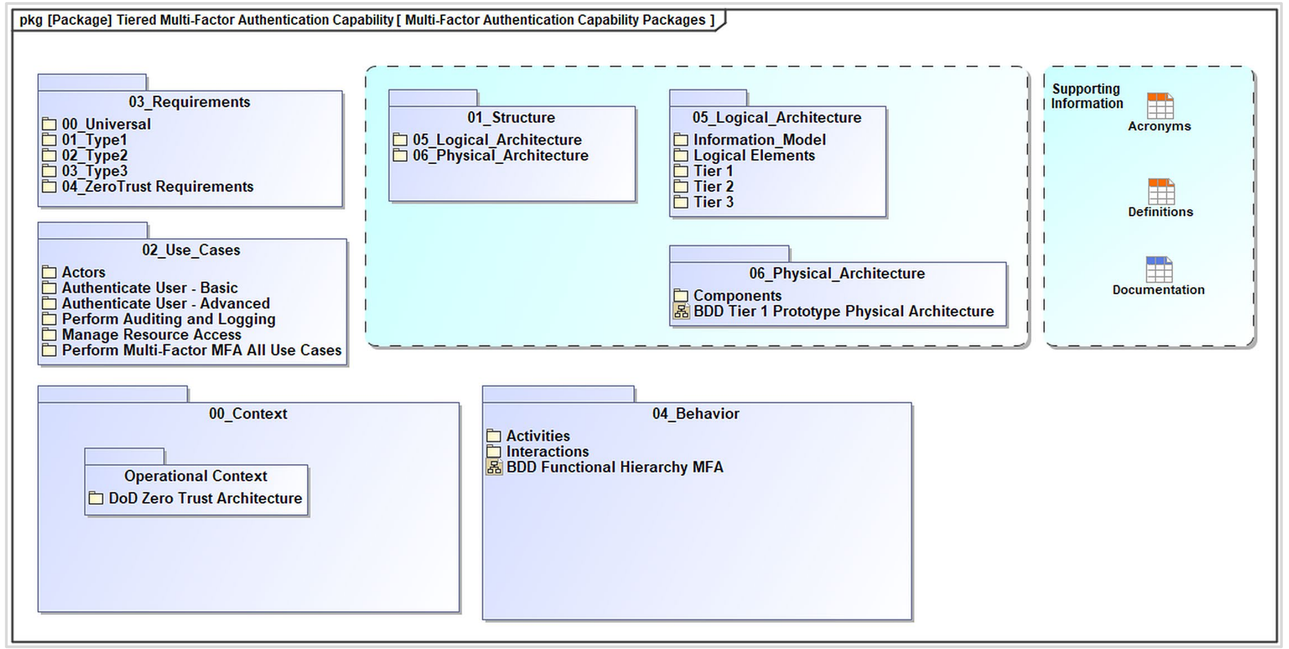
Domain context, package structure and glossary, use cases, universal requirements

2. Derive structure

Functional hierarchy, activities, tier-specific requirements, logical architecture per tier

3. Couple and refine

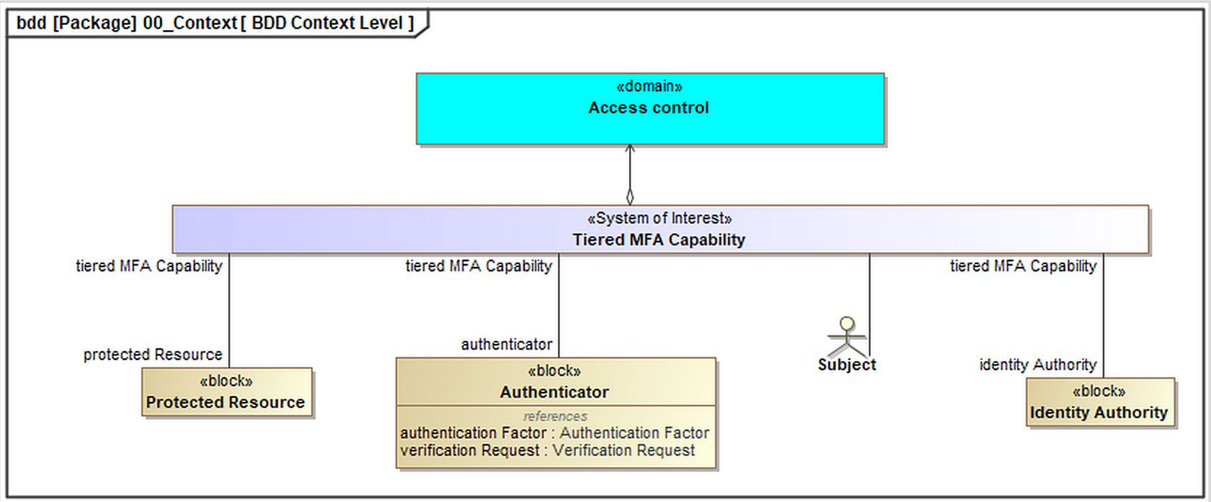
Allocate logical elements to the prototype; refine model and prototype in parallel



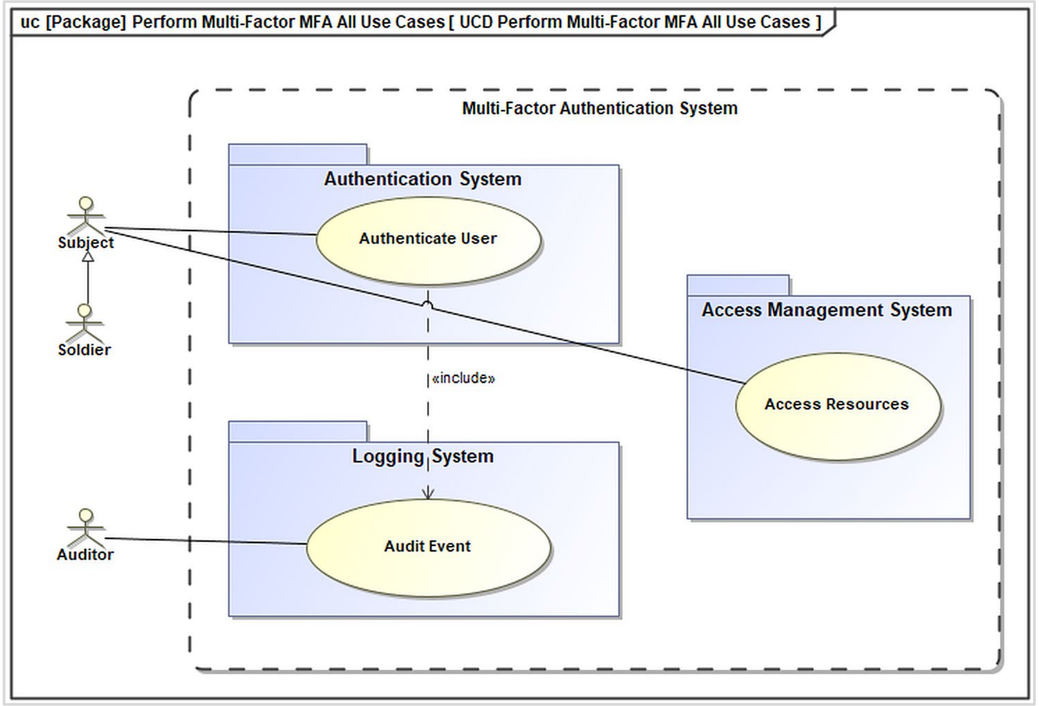
Model package structure (Cameo Systems Modeler)

Governing the model

Context and use cases



Context BDD

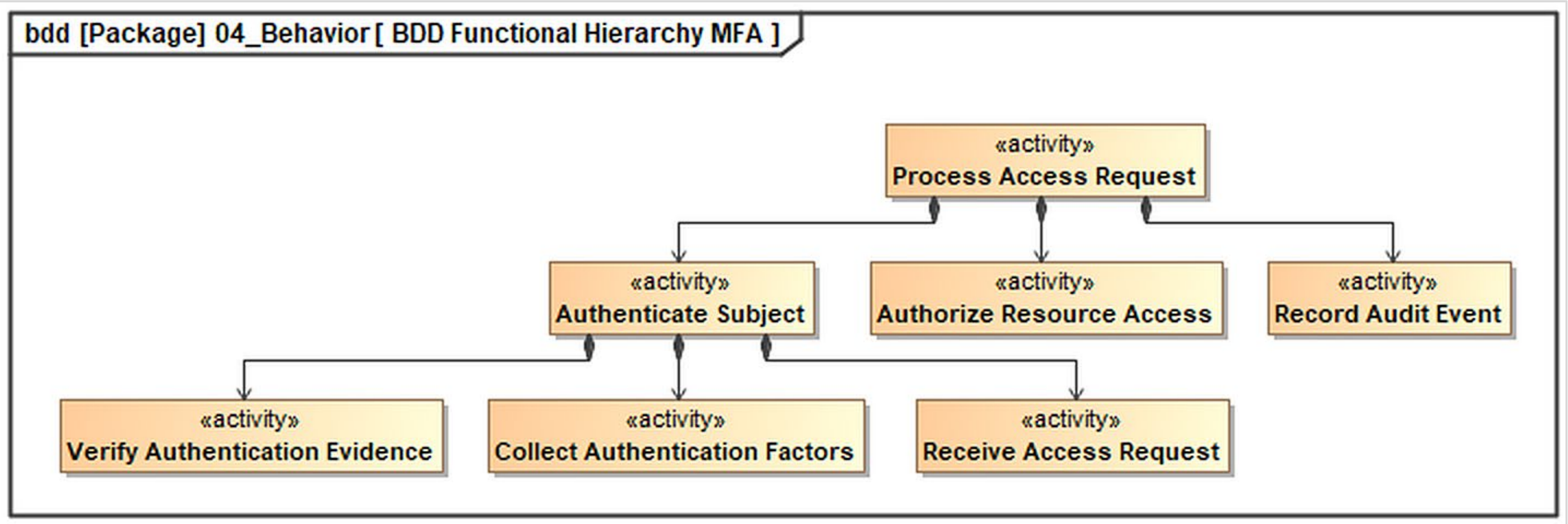


Use cases

- System of interest: the tiered MFA capability
- Tier selection is made by the host CPS, outside this boundary
- Protected Resource carries no properties yet

Deriving structure

The functional hierarchy



Functional hierarchy BDD

- Authentication, authorization, and audit are separate responsibilities from the start
- Activities refined selected functions, such as factor collection and evidence verification

Three tiers

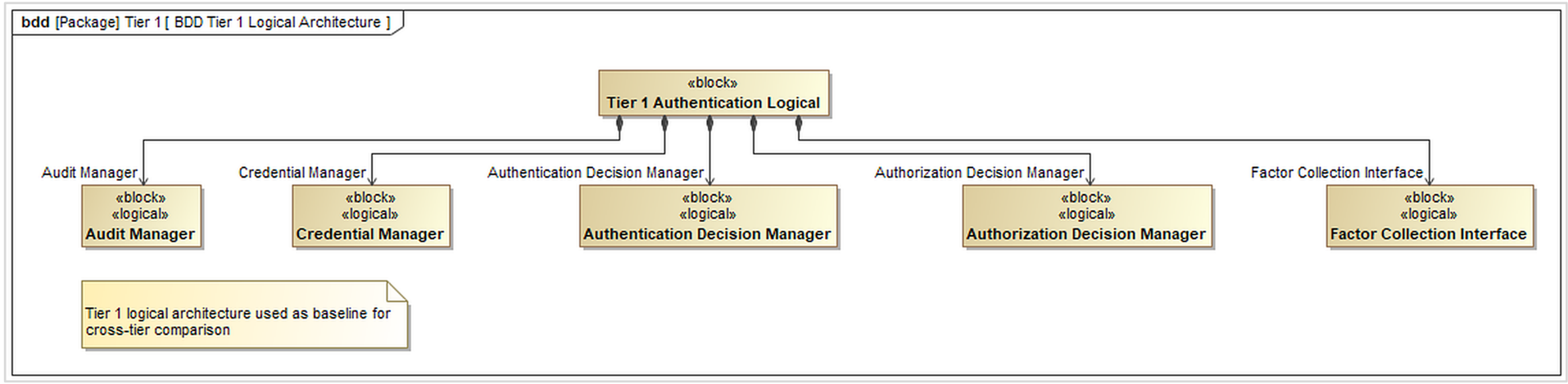
Derived from one universal requirement set

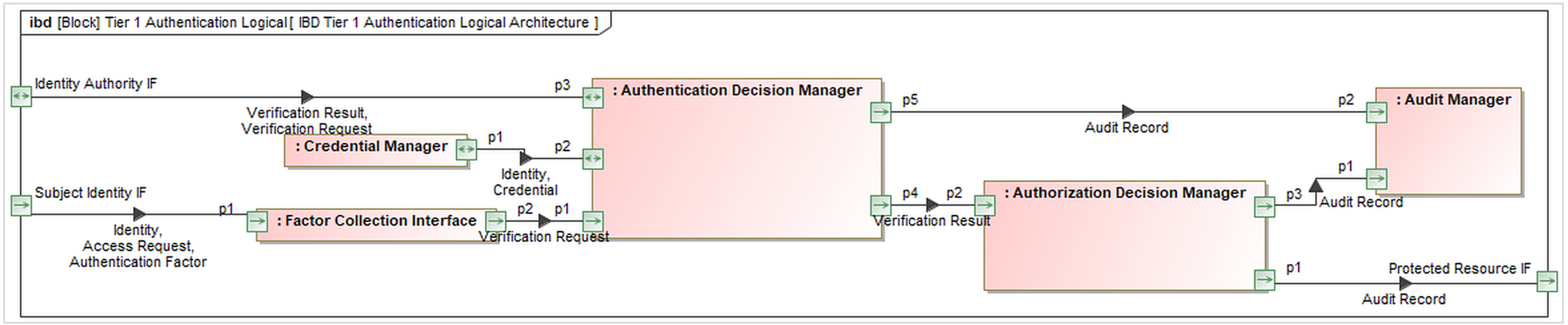
Tier	Operating condition	Required factors	Access scope	Audit / accountability
Tier 1	Highest-complexity normal operation	RFID + fingerprint	Standard protected access	Strict audit
Tier 2	Simplified normal protected access	RFID + PIN	Standard protected access	Strict audit
Tier 3	Degraded mission-continuity access	RFID + PIN	Only resources approved for degraded access	Strict audit; deferred transmission permitted

- Not a strongest-to-weakest ranking: different responses to different operating conditions
- Each tier's requirements derive from the same universal set, so the tiers compare as sets

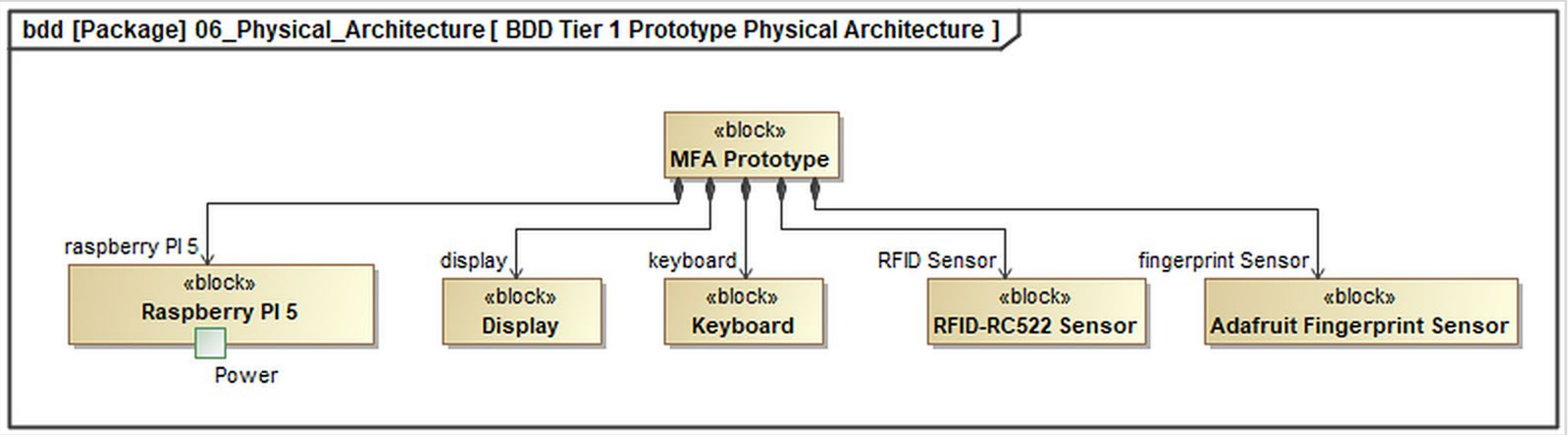
Logical architecture

Responsibilities before hardware





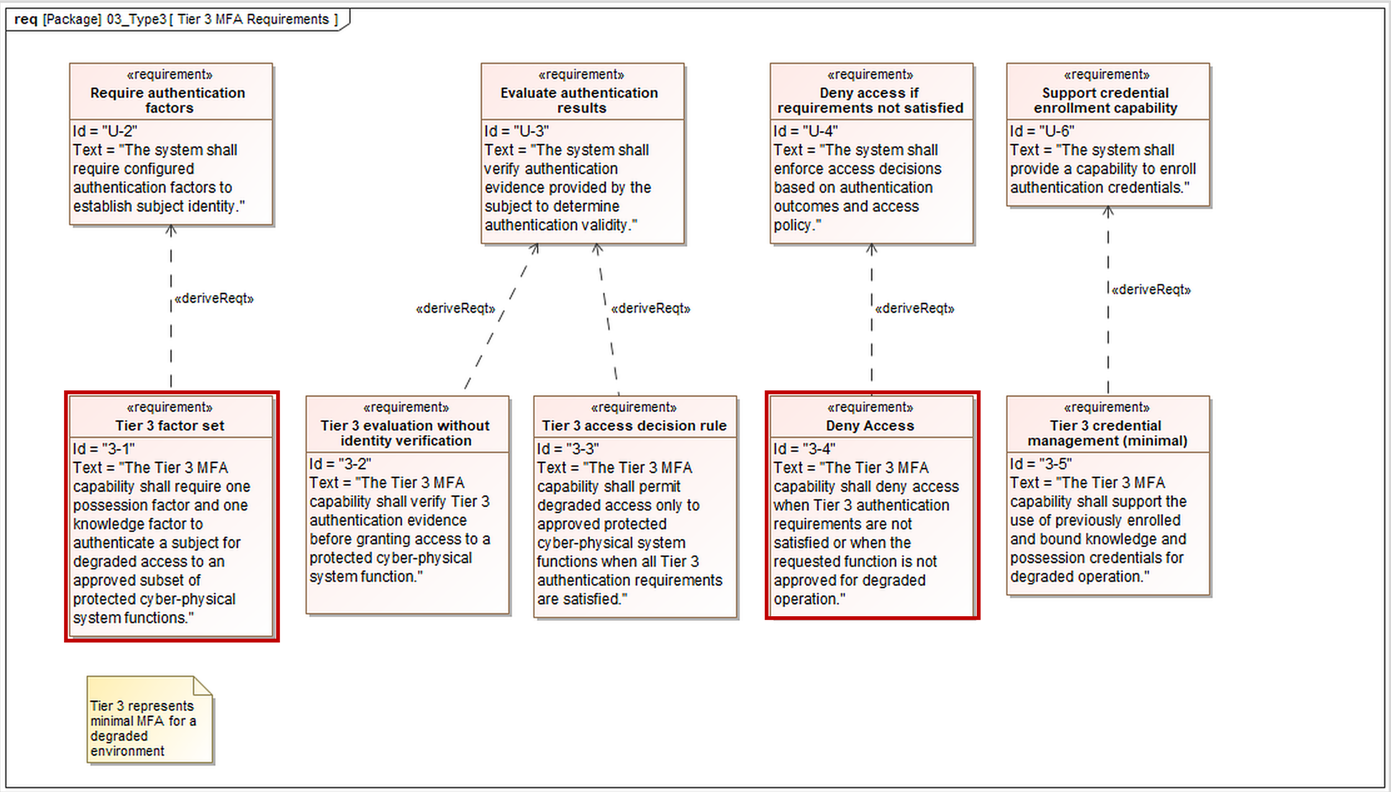
Model-to-prototype traceability



Logical element	Realized in the prototype
Factor Collection Interface	Node-RED flows calling the RFID and fingerprint scripts over local HTTP
Authorization Decision Manager	`services._evaluate_authorization`
Tier 3 degraded access	`ProtectedResource.allow_degraded_access`
Audit Manager	`AuditEvent`

Finding 1

A tier is defined by more than its authentication factor set



Tier 3 requirements, derived from the universal set

- **3-1** authenticates “for degraded access to an approved subset of protected cyber-physical system functions”
- **3-4** denies “when the requested function is not approved for degraded operation”
- Same factors as Tier 2; the scope check is separate from the factor check
- A tier is a **joint constraint** over factors, scope, precondition, and accountability

Finding 2

A stronger factor adds no protection if a weaker tier grants the same access

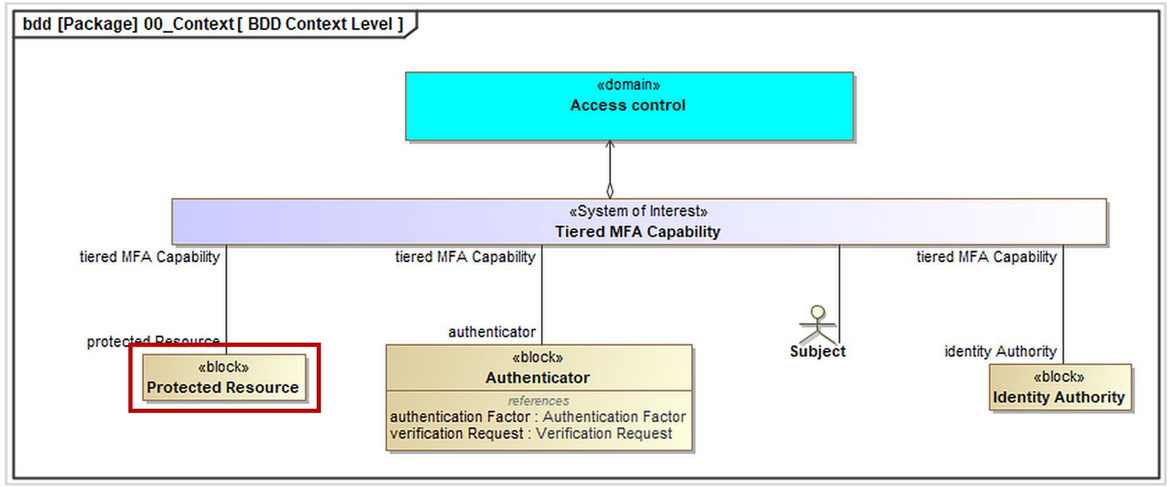
- Adversary: cloned RFID and known PIN, but no fingerprint
- Minimum-tier enforcement reduces access; legitimate Tier 1 retains full access

Scenario	Asserted tier	Minimum-tier check	Reached
Adversary · baseline	Tier 2	Off	**20 of 20**
Adversary · hardened	Tier 2	On	**10 of 20**
Adversary · degraded	Tier 3	On	**5 of 20**
Legitimate control	Tier 1	On	**20 of 20**

Source: public run_experiments.py / README, scenarios 1–4; mocked sensors; audit sink available.
Fixture: 20 resources; 10 require Tier 1; 5 different resources permit degraded access.

Making required assurance expressible

A minimum tier per resource



Context BDD: Protected Resource

- Added a minimum tier to each protected resource
- Tier 1-only resources reject Tier 2
- Assigning tiers to resources becomes an explicit policy decision

```python
# models.py
class ProtectedResource(models.Model):
    allow_degraded_access = ...
    minimum_tier = models.CharField(...)

# services.py, _evaluate_authorization
asserted_rank = tier_assurance_rank(
    _selected_tier(session))
minimum_rank = tier_assurance_rank(
    session.resource.minimum_tier)
if asserted_rank < minimum_rank:
    return {"ok": False, "reason_code":
        "insufficient_tier_assurance", ...}
```

Excerpt, github.com/noahstephenson/MFA-System

Finding 3

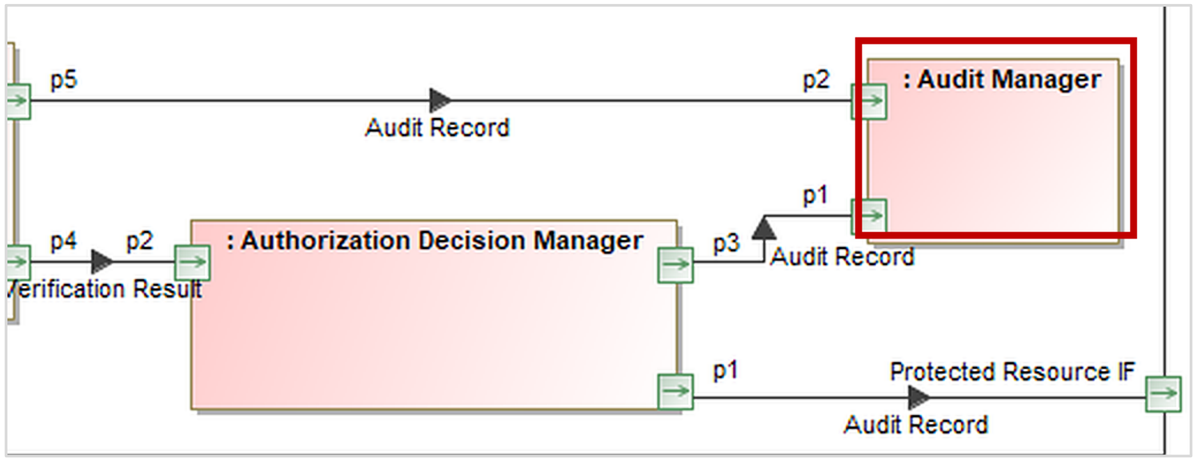
Minimum assurance above Tier 3 and degraded access cannot both be satisfied

- Each resource has two settings: minimum assurance and degraded-access approval
- The implemented ordering ranks Tier 3 below Tiers 1 and 2
- Mission-essential resources may need both; this policy cannot provide both
- Generalizes when degraded assurance is below an unconditional minimum

Requester asserts Tier 3	Not approved for degraded access	Approved for degraded access
Minimum tier: Tier 3 (default)	Denied	Reachable
Minimum tier: Tier 1 or 2	Denied	**Unreachable: the approval flag is dead configuration**

Finding 4

The model's accountability requirement held where the implementation and its tests did not



Tier 1 IBD: the Audit Manager receives audit records from both decision managers

- Fault: session-start record succeeds; later audit writes fail
- Unaudited approvals by scenario

Scenario	Before	After
Tier 2 · baseline	**20**	**0**
Tier 2 · hardened	**10**	**0**
Tier 3 · degraded	**5**	**0**
Tier 1 · control	**20**	**0**

Source: run_experiments.py, mid-flow failure matrix.

The governing model surfaced the gap and defined the fix

Enforcing the requirement

An approval cannot stand without its audit record

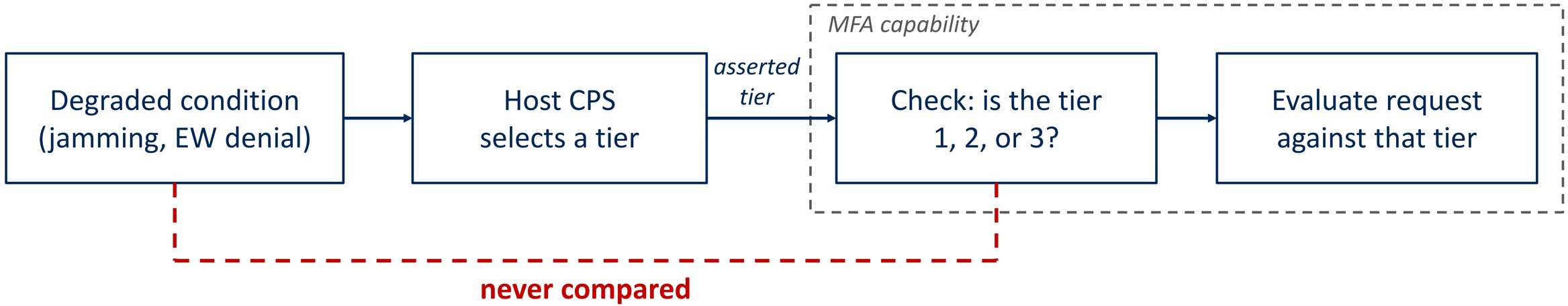
- If the access-decision audit write fails, the approved session is changed to denied
- No access decision persists as approved without a durable record
- Unaudited approvals: zero in all three tiers
- Accountability is held over availability, as the model requires

```
# services.py, access decision event
try:
    create_audit_event("access_granted", ...)
except Exception:
    if access_granted:
        # Fail closed: ... it cannot stand
        # without a durable audit record ...
        access_granted = False
        session.status = ...DENIED
        session.save(...)
```

Excerpt, github.com/noahstephenson/MFA-System

Finding 5

The operating tier is an input to the capability, not an output of it



- The capability validates the tier label, not the condition that justifies it
- Baseline policy: an attacker can assert Tier 2 during degradation and reach full scope
- Next: bind tier selection to a condition the capability derives or attests

Finding 6

Model governance and structured decomposition are what made the tiers comparable

- Shared glossary and package structure; every tier derived from one universal requirement set
- Separating authentication from authorization made Findings 1 and 5 observable

Finding	Properties composed	Outcome
1	Tier factors with scope, precondition, accountability	Tier defined as a joint constraint
2	Shared scope with required assurance	Minimum tier per resource
3	Minimum tier with degraded-access approval	Composition constraint identified
4	Approval with its audit record	Fail-closed audit
5	Asserted tier with observed condition	Next step: attested tier selection

Structured decomposition and composition: NIST SP 800-160 Vol. 1 Rev. 1 (2022)

Limitations

- Prototype evidence, not formal security validation or operational certification
- Mocked sensors and database resources: authorization decisions, not downstream enforcement
- Configured degradation and injected audit failures, not field jamming
- Zero Trust informed; not evaluated against a defined baseline
- One tier configuration; generalizations retain the same policy assumptions

Conclusion

Degraded operation must be a verified policy, not just a weaker factor set.

1. Define each mode as a joint constraint over factors, scope, precondition, and accountability
2. State invariants between properties specified separately: minimum assurance with degraded access, approval with its record
3. Treat the operating mode as a security-relevant input, and bind it to a condition the capability derives or attests

Next: verify tier conditions; guard and record transitions; derive tests from the model

noah.stephenson@westpoint.edu
github.com/noahstephenson/MFA-System

References

E. Dauterman, D. Lin, H. Corrigan-Gibbs, and D. Mazières, “Accountable authentication with privacy protection: The Larch system for universal login,” in Proc. OSDI ’23, 2023.

Department of Defense, “DoD zero trust reference architecture, version 2.0,” DISA and NSA Zero Trust Engineering Team, 2022.

S. Friedenthal, A. Moore, and R. Steiner, A Practical Guide to SysML, 3rd ed. Morgan Kaufmann, 2015.

S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero trust architecture,” NIST SP 800-207, 2020.

R. Ross, M. Winstead, and M. McEvilley, “Engineering trustworthy secure systems,” NIST SP 800-160 Vol. 1 Rev. 1, 2022.

D. Temoshok et al., “Digital identity guidelines: Authentication and authenticator management,” NIST SP 800-63B-4, 2025.

N. Stephenson and M. Wolfe, MFA-System experiment harness and results, github.com/noahstephenson/MFA-System.